

## Phish\_Scan modifications

Phish\_scan2.py – the new python script

Feedback received:

1. Make the authentication check trust aware. Rather than believing any Authentication-Results, parse the Received header chain and only honor the results stamped by the final trusted hop. This will stop an attacker from self-certifying a clean bill of health.
2. Provide HTML and JSON output options.
3. Fix readme file to show plain flags.
4. Reject non-eml files.
5. Passing off contents of emails to a third party for scanning and validation.
6. Add an allow list to mute internal senders.

Feedback implemented:

1. I have made the authentication trust-aware and have included a sample email to test the option.
2. The tool now has HTML and JSON output options.
3. Readme file is fixed to show plain flags (-h).
4. Tool now rejects non-eml files.

Feedback not implemented:

1. Passing off contents of email to a third party for scanning and validation. I felt this is an excellent idea and would make the tool more dynamic and updated. I also felt that this would be a completely new tool.
2. Add an allow list to mute internal senders. I felt this would partially defeat checking all emails and a spoofed email from an internal sender would go unnoticed.

New command line options for json, html:

```
python3 phish_scan.py ./emails --json report.json
```

```
python3 phish_scan.py ./emails --html report.html
```

```
python3 phish_scan.py ./emails --csv report.csv --json report.json --html report.html
```

Output examples

Program options:

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan2.py -h
usage: phishing_scanner [-h] [--csv OUT.csv] [--json OUT.json] [--html OUT.html] target

Heuristically score .eml files as legitimate or phishing.

positional arguments:
  target                Path to a .eml file or a directory containing .eml files

options:
  -h, --help            show this help message and exit
  --csv OUT.csv         Write a CSV summary report to this path
  --json OUT.json       Write a JSON report to this path
  --html OUT.html       Write an HTML report to this path
patrickturner@PDTUbuntu:~/Desktop/tool4$
```

Self cert email test:

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ python3 phish_scan2.py phishing_selfcert.eml
```

PHISH SCAN

```
SUSPICIOUS 58/100 ██████████
Important: Unusual sign-in detected on your account
from: Wells Fargo Alerts <alerts@wellsfarg0-secure.com>
file: phishing_selfcert.eml

HIGH + 25 Display name references 'Wells Fargo' but sending domain 'wellsfarg0-secure.com' does not match the legitimate domain (wellsfargo.com).
HIGH + 15 Body text asks the recipient to re-enter credentials, card details, or personal identifiers.
MEDIUM + 8 Authentication-Results header present but not attributable to a trusted delivery hop; any 'pass' claims are ignored, since a message's own sender could write that line itself.
MEDIUM + 5 Contains 1 urgency/pressure phrase(s) commonly used in phishing (e.g. threats of account suspension, deadlines, 'act now').
LOW + 5 Uses a generic greeting instead of the recipient's name, common in mass-sent phishing.
```

---

```
SUMMARY
1 email(s) scanned
SUSPICIOUS 1
patrickturner@PDTUbuntu:~/Desktop/tool4$
```

## HTML output:

Phishing Scan Report

5 email(s) scanned

|             |   |
|-------------|---|
| LOW RISK    | 4 |
| LIKELY SAFE | 1 |

LOW RISK 33/100

**Ernst & Young Breach Affects Personal, Financial Information**

from: SecurityWeek Briefing <news@securityweek.com>  
file: emails/Ernst & Young Breach Affects Personal, Financial Information.eml

**HIGH** +25 Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com.

**MEDIUM** +8 Authentication-Results header present but not attributable to a trusted delivery hop; any 'pass' claims are ignored, since a message's own sender could write that line itself.

LOW RISK 33/100

**Patrick, your weekly Hannaford flyer has arrived**

from: Hannaford Supermarkets <noreply@messages.hannaford.com>  
file: emails/Patrick, your weekly Hannaford flyer has arrived.eml

**HIGH** +25 Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com.

**MEDIUM** +8 Authentication-Results header present but not attributable to a trusted delivery hop; any 'pass' claims are ignored, since a message's own sender could write that line itself.

LOW RISK 33/100

## JSON output:

```
patrickturner@PDTUbuntu:~/Desktop/tool4$ cat json.json | more
```

```
[
  {
    "path": "emails/Ernst & Young Breach Affects Personal, Financial Information.eml",
    "subject": "Ernst & Young Breach Affects Personal, Financial Information",
    "from_display": "SecurityWeek Briefing",
    "from_addr": "news@securityweek.com",
    "score": 33,
    "verdict": "LOW RISK",
    "findings": [
      {
        "check": "link_brand_lookalike",
        "points": 25,
        "severity": "high",
        "reason": "Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com."
      },
      {
        "check": "authentication",
        "points": 8,
        "severity": "medium",
        "reason": "Authentication-Results header present but not attributable to a trusted delivery hop; any 'pass' claims are ignored since a message's own sender could write that line itself."
      }
    ]
  },
  {
    "path": "emails/Patrick, your weekly Hannaford flyer has arrived.eml",
    "subject": "Patrick, your weekly Hannaford flyer has arrived",
    "from_display": "Hannaford Supermarkets",
    "from_addr": "noreply@messages.hannaford.com",
    "score": 33,
    "verdict": "LOW RISK",
    "findings": [
      {
        "check": "link_brand_lookalike",
        "points": 25,
        "severity": "high",
        "reason": "Link domain 'fonts.googleapis.com' looks like a lookalike of google.com/gmail.com."
      },
      {
        "check": "authentication",
        "points": 8,
        "severity": "medium",
        "reason": "Authentication-Results header present but not attributable to a trusted delivery hop; any 'pass' claims are ignored since a message's own sender could write that line itself."
      }
    ]
  }
]
```